LENGUAJE DE PROGRAMACIÓN 2

Pruebas de seguridad y gestión de acceso

Actividad autónoma - Sesión 10 | PharmaSoft

Estudiante
James Christopher Tequen Oncoy

Docente
Benjamin David Reyna Barreto

Fecha de ejecución
17/10/2026 - America/Lima

Entrega de S10 Autónoma

16 casos base, 4 propios de grupos distintos y B-01 a B-08. Los 28 casos pasan; cada uno tiene su evidencia identificada.

Informe C1-C3: páginas 2 a 4. Las fichas siguientes agrupan las peticiones de cada caso y muestran una captura representativa. Las capturas adicionales permanecen enlazadas en la matriz del repositorio.

Repositorio: PR #1 hacia master. Queda pendiente cumplir los commits de S10 en días distintos.

Informe de seguridad

PharmaBackend · Actividad autónoma · Sesión 10

Estudiante: James Christopher Tequen Oncoy
Curso: Lenguaje de Programación 2
Docente: Benjamin David Reyna Barreto
Fecha de ejecución: 17 de octubre de 2026

C1. Resumen de resultados

Grupo	Casos	Pasan	Fallan
Autenticación	5	5	0
Token	6	6	0
Permisos	5	5	0
Usuarios	3	3	0
CORS	1	1	0
Contraseña, roles y estado	8	8	0
Total	**28**	**28**	**0**

Se ejecutaron **28 casos** mediante 62 peticiones o comprobaciones registradas: los 16 casos base, cuatro propios de grupos distintos y B-01 a B-08.

Los casos propios son A-05 (credenciales vacías), T-06 (Authorization ausente), P-05 (unión de permisos de supervisor) y U-03 (administración de usuarios por vendedor). Las respuestas distinguen la falta de autenticación del rechazo por permisos.

Entorno y trazabilidad

Oracle 23 en Docker; API principal en localhost:8081; Swagger UI; SPA existente servida en localhost:4200. Para T-03 se inició el mismo JAR en 8082 con otra clave. Esa instancia también emitió el JWT de T-04 con duración de un minuto; se utilizó después de su vencimiento real.

La matriz detalla cada petición, código, mensaje y captura original. Las fichas reúnen los resultados de cada caso y una captura representativa; la verificación de persistencia se incorpora desde DBeaver. Las capturas adicionales se conservan enlazadas en el repositorio. Los datos de negocio son nombres y productos normales.

C2. Hallazgos y verificación

No hubo casos funcionales fallidos en la ejecución final. Por ello no corresponde elaborar fichas de fallos con severidad, causa y corrección. Las respuestas de rechazo esperadas forman parte de los casos que pasan.

Resultados de los endpoints construidos

Operación	Reglas comprobadas y resultado
PUT /auth/password	204 al cambiar; 400 por formato o longitud; 409 por contraseña actual incorrecta o nueva idéntica. La cuenta se toma de Authentication.getName(). BCrypt verifica y codifica; la respuesta no contiene contraseña.
PUT /usuarios/{id}/roles	200 al reemplazar roles; 400 por conjunto vacío; 404 por usuario o rol inexistente; 409 si el administrador intenta quitarse ADMIN. Un vendedor recibe 403.
PATCH /usuarios/{id}/estado	200 al desactivar y reactivar; 404 si el usuario no existe; 409 ante autodesactivación del administrador; 403 sin permiso. La cuenta desactivada pierde acceso con su token previo y su login devuelve el mensaje genérico.

Comprobaciones de persistencia y registro

U-02 creó la cuenta de María Huamán con una única relación VENDEDOR. La consulta a usuarios y usuario_roles confirmó un hash BCrypt con prefijo $2a$10$; el DTO no expone password. B-05 dejó exactamente dos relaciones para vendedor: ALMACENERO y VENDEDOR. La comprobación compartida en DBeaver muestra el hash y la única relación de María, y las dos relaciones del vendedor durante B-05. Con el mismo JWT se obtuvo el nuevo permiso porque JwtAuthenticationFilter recarga usuario, estado y authorities desde la base en cada petición.

B-01 confirmó un registro INFO “Contraseña actualizada: usuario=vendedor”; se verificó que las contraseñas enviadas no aparezcan en el log. Tras las pruebas se restituyeron la contraseña y los roles originales del vendedor; la cuenta maria creada en U-02 permanece registrada.

Límites y estado de la entrega

Las evidencias corresponden al entorno local de clase. C-01 registró el OPTIONS y el GET reales del navegador con respuesta 200 y el origen permitido localhost:4200. La colección exportada deja vacías todas las variables de tokens.

Versionamiento: rama feature/seguridad-pruebas-Tequen, creada desde feature/dev-TEQUEN, la rama de trabajo disponible. No existía la rama de práctica indicada. Los commits llevan su fecha real del 17/10/2026; **queda pendiente el requisito de commits en días distintos**. El PR #1 está abierto hacia master, creada en el mismo commit base de main para respetar la guía: https://github.com/LeonardoTA/PharmaBackend/pull/1. El criterio completo de versionamiento no se considera cumplido.

C3. Análisis de seguridad

1. Respuesta genérica del login

El mismo mensaje “Usuario o contraseña incorrectos” evita que la respuesta distinga una cuenta inexistente, una contraseña equivocada y una cuenta deshabilitada. Un mensaje diferente permitiría enumerar usuarios válidos o conocer su estado para dirigir intentos contra ellos. GlobalExceptionHandler.handleAuthentication aplica la respuesta común a AuthenticationException; A-02 y A-03 comprobaron la igualdad del mensaje. Esto reduce la información expuesta por el texto; no demuestra igualdad de tiempos de respuesta.

2. Token anterior después del cambio de contraseña

El JWT conserva una firma y una fecha de expiración válidas: AuthServiceImpl.cambiarPassword modifica el hash BCrypt, pero no revoca los tokens emitidos. JwtAuthenticationFilter.doFilterInternal comprueba firma y expiración, luego consulta usuario, estado y permisos; no compara la contraseña ni una versión de credencial. B-01 confirmó que el token anterior sigue funcionando. Una solución es guardar tokenVersion en usuarios e incluirla en el JWT: al cambiar la contraseña se incrementa la versión y el filtro rechaza tokens con una versión anterior.

3. Publicación accidental del secreto

Quien obtiene la clave HMAC puede firmar un JWT que suplante el sub de un usuario existente, incluso admin. Aunque el filtro recarga los permisos desde la base y no confía en las authorities del payload para autorizar, suplantar un administrador sigue siendo crítico. Se debe rotar inmediatamente la clave, retirar la anterior de todas las instancias, revisar accesos, reemplazar credenciales comprometidas y retirar el secreto del repositorio y su historial. JwtService recibe la clave desde JWT_SECRET; T-03 confirmó que otra clave rechaza el token anterior.

4. Protección de reportes con @PreAuthorize

La anotación del ReporteController liga el permiso REPORTES_VER al controlador y sus métodos, de modo que cambiar una URL no elimina esa protección si la anotación permanece. SecurityConfig mantiene además la autenticación general. P-03 comprobó el rechazo para vendedor y almacén. La desventaja es que las reglas quedan distribuidas entre la configuración y las anotaciones, lo que dificulta revisar toda la política. También depende de @EnableMethodSecurity y de que la invocación pase por el proxy de Spring; una llamada interna puede no ser interceptada.

Referencias al código verificado

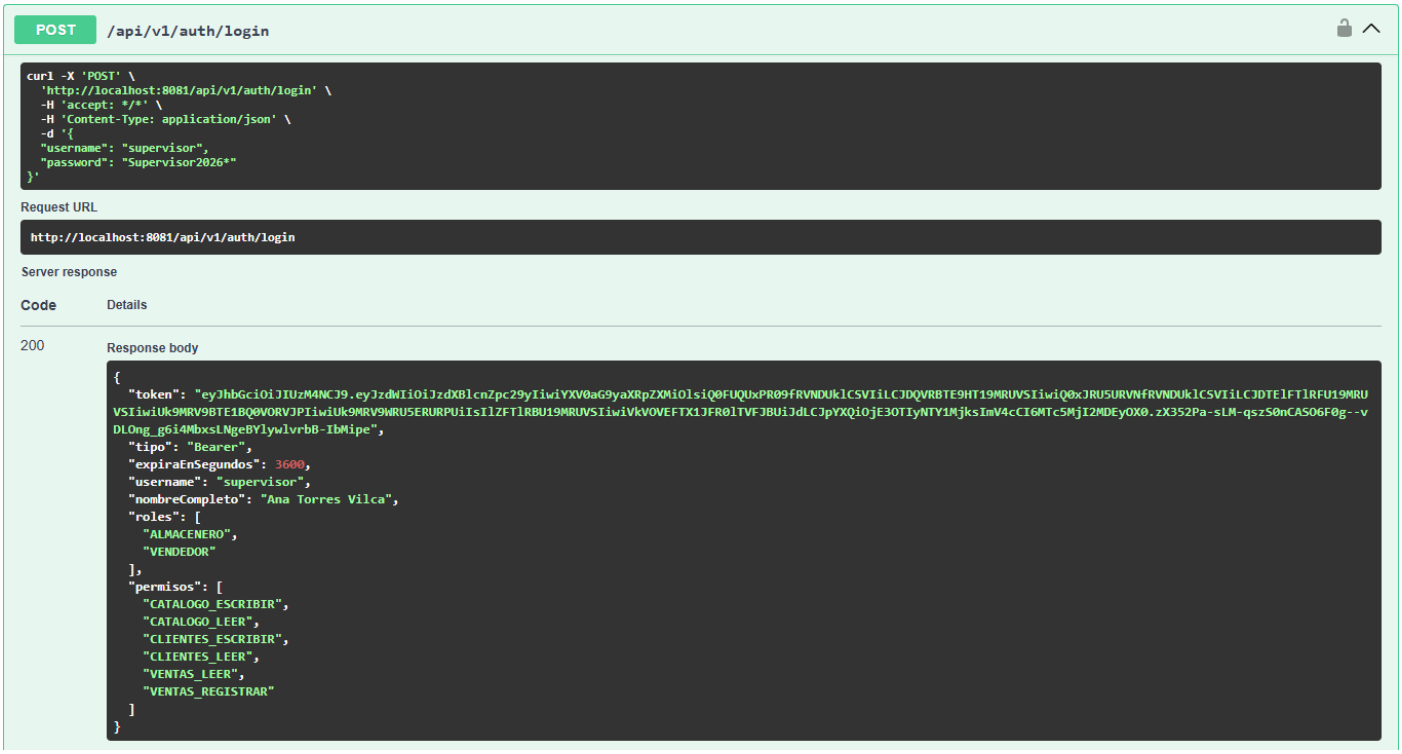
Paquete pe.edu.upeu.PharmaBackend: controller/AuthController y ReporteController; service/impl/AuthServiceImpl y UsuarioServiceImpl; security/JwtAuthenticationFilter, JwtService, UsuarioDetailsService y PermisosPorRol; config/SecurityConfig; exception/GlobalExceptionHandler. Los casos correspondientes y los resultados completos se encuentran en la matriz y en el anexo.

A-01 · Login y permisos por rol · PASA

Autenticación | Usuario/token: Público / Ausente

Esperado = obtenido: 200 en los cuatro roles; supervisor combina los permisos de VENDEDOR y ALMACENERO.

Petición	Esperado	Obtenido
POST /auth/login · admin	200	200
POST /auth/login · vendedor	200	200
POST /auth/login · almacen	200	200
POST /auth/login · supervisor	200	200



A-01_04_swagger.png · Captura original en el repositorio.

A-02 · Credenciales incorrectas · PASA

Autenticación | Usuario/token: Público / Ausente

Esperado = obtenido: 401 con el mismo mensaje: Usuario o contraseña incorrectos.

Petición	Esperado	Obtenido
POST /auth/login · carmen	401	401
POST /auth/login · vendedor	401	401



A-02_02_swagger.png · Captura original en el repositorio.

A-03 · Cuenta inactiva · PASA

Autenticación | Usuario/token: Público / Ausente

Esperado = obtenido: 401 con el mensaje genérico: Usuario o contraseña incorrectos.

Petición	Esperado	Obtenido
POST /auth/login · inactivo	401	401



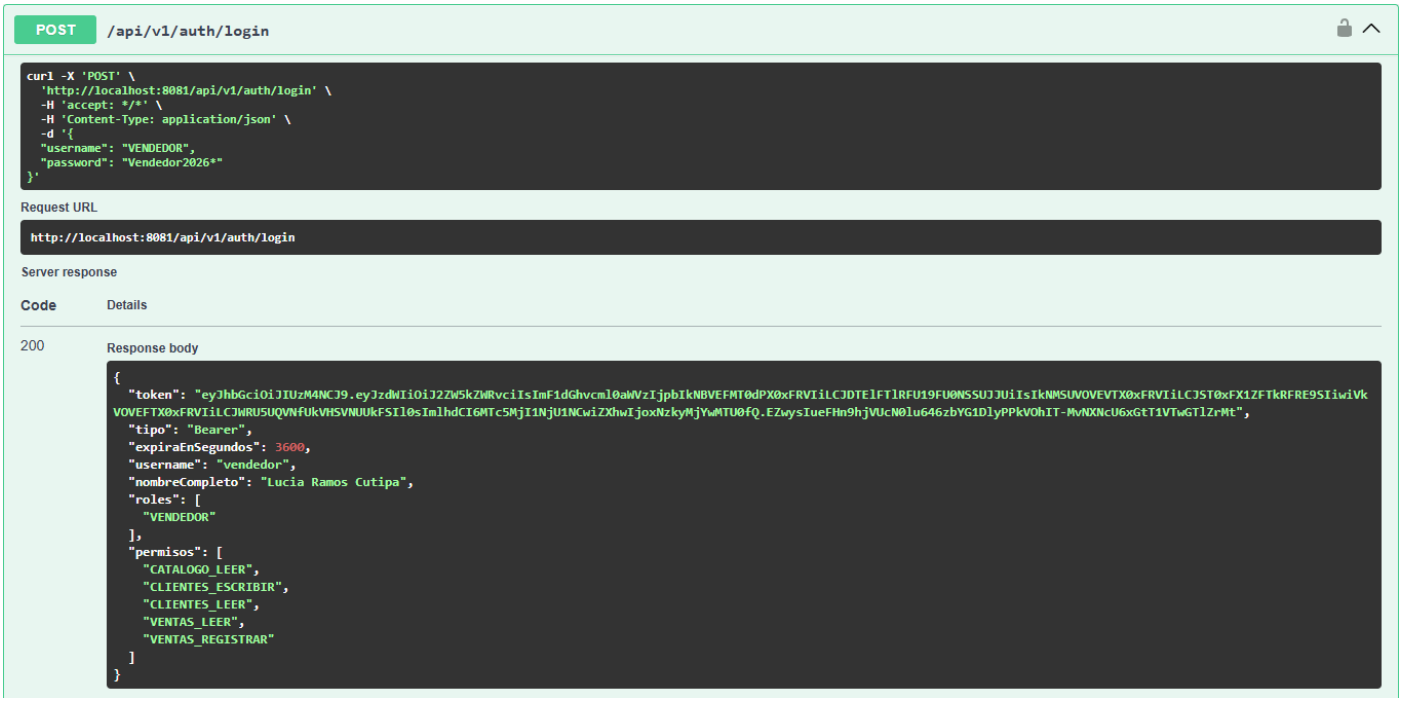
A-03_01_swagger.png · Captura original en el repositorio.

A-04 · Username en mayúsculas · PASA

Autenticación | Usuario/token: Público / Ausente

Esperado = obtenido: 200; VENDEDOR identifica la cuenta vendedor sin distinguir mayúsculas.

Petición	Esperado	Obtenido
POST /auth/login · VENDEDOR	200	200



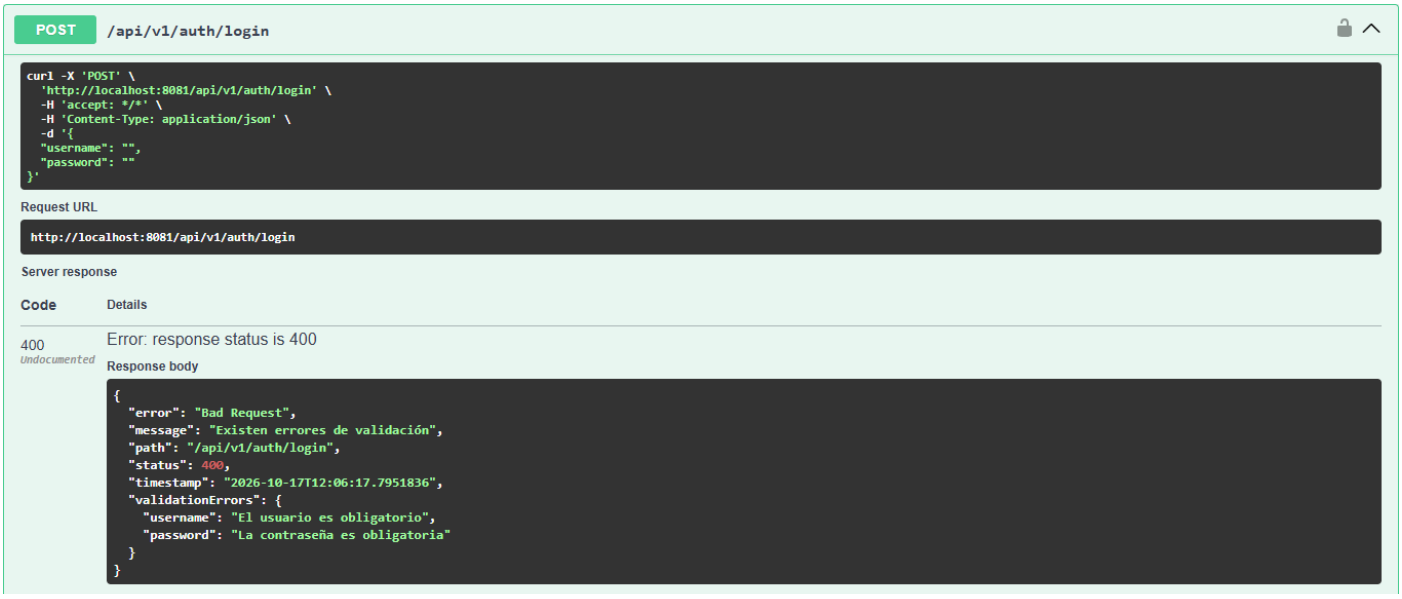
A-04_01_swagger.png · Captura original en el repositorio.

A-05 · Credenciales vacías (propio) · PASA

Autenticación | Usuario/token: Público / Ausente

Esperado = obtenido: 400; username y password vacíos se rechazan por validación.

Petición	Esperado	Obtenido
POST /auth/login ·	400	400



A-05_01_swagger.png · Captura original en el repositorio.

T-01 · Token sin Bearer · PASA

Token | Usuario/token: vendedor / Sin prefijo Bearer

Esperado = obtenido: 401; Debe iniciar sesión para acceder a este recurso.

Petición	Esperado	Obtenido
GET /auth/me	401	401



T-01_01_swagger.png · Captura original en el repositorio.

T-02 · Payload alterado · PASA

Token | Usuario/token: vendedor / Bearer

Esperado = obtenido: 401; El token no es válido.

Petición	Esperado	Obtenido
GET /auth/me	401	401



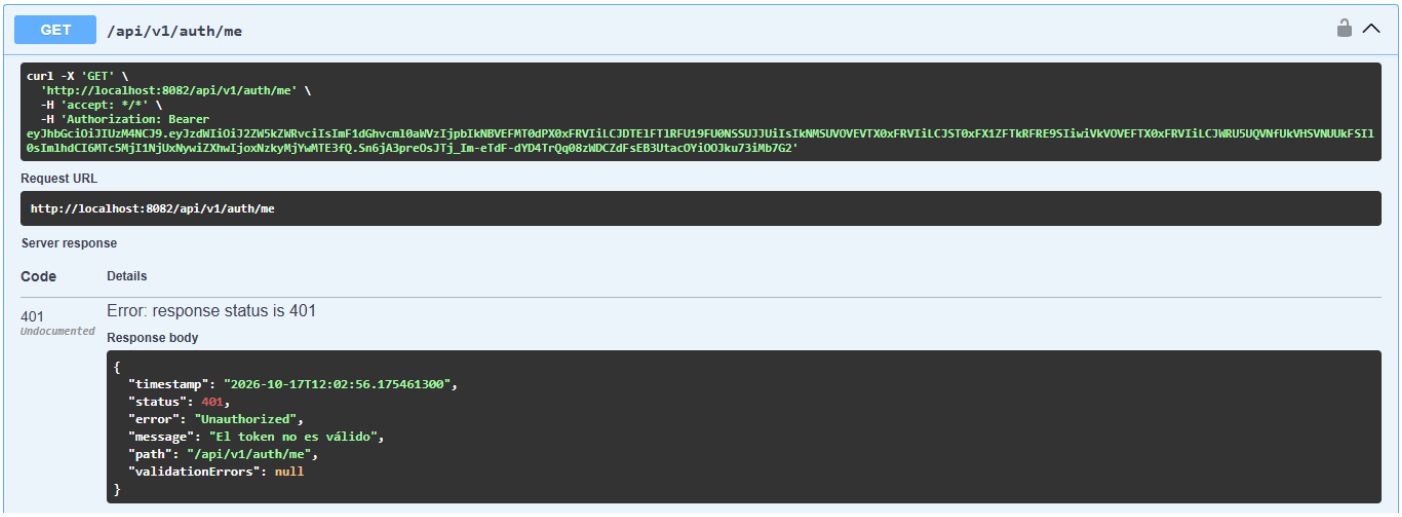
T-02_01_swagger.png · Captura original en el repositorio.

T-03 · Firma con otra clave · PASA

Token | Usuario/token: vendedor / Bearer

Esperado = obtenido: 401; El token no es válido al verificarlo con otra clave.

Petición	Esperado	Obtenido
GET /auth/me	401	401



T-03_01_swagger.png · Captura original en el repositorio.

T-04 · Vencimiento real · PASA

Token | Usuario/token: vendedor / Bearer

Esperado = obtenido: 401; El token ha expirado. Inicie sesión nuevamente, tras esperar el minuto real.

Petición	Esperado	Obtenido
GET /auth/me	401	401



T-04_01_swagger.png · Captura original en el repositorio.

T-05 · Payload y datos sensibles · PASA

Token | Usuario/token: vendedor / Bearer

Esperado = obtenido: 200 en /auth/me; payload con sub, authorities, iat y exp, sin contraseña ni datos sensibles.

Petición	Esperado	Obtenido
GET /auth/me	200	200

GET /api/v1/auth/me

```
curl -X 'GET' \
  'http://localhost:8081/api/v1/auth/me' \
  -H 'accept: */*' \
  -H 'Authorization: Bearer
eyJhbGciOiJIUzM4NCJ9.eyJzdWIiOiJ2ZW5kZWRvciIsImF1dGhvcml0aWVzIjpbIkNBVEFMT0dPX0xFRVIiLCJDTE1FT1RFU19FU0NSSUJJUiIsIkNMSUVOVEVEVTX0xFRVIiLCJST0xFX1ZFTkRFRE9SIiwiVkVOVEFTX0xFRVIiLCJWRU5UQVNfUkVHSVNUUkFSIl
0sImlhdCI6MTc5MjI1NjUxNywiZXhwIjoxNzkyMjYwMTE3fQ.Sn6jA3preOsJTj_Im-eTdF-dYD4TrQq08zWDCZdFsEB3UtacOYiOOJku73iMb7G2'
```

Request URL

```
http://localhost:8081/api/v1/auth/me
```

Server response

Code | Details

200

Response body


```
{
  "id": 2,
  "username": "vendedor",
  "empleadoId": 2,
  "empleadoNombre": "Lucia Ramos Cutipa",
  "cargo": "Vendedora",
  "roles": [
    "VENDEDOR"
  ],
  "permisos": [
    "CATALOGO_LEER",
    "CLIENTES_ESCRIBIR",
    "CLIENTES_LEER",
    "VENTAS_LEER",
    "VENTAS_REGISTRAR"
  ],
  "estado": true,
  "fechaCreacion": "2026-10-17T16:57:52.705694"
}
```


Payload real: sub=vendedor; iat=1792256517; exp=1792260117; authorities=CATALOGO_LEER, CLIENTES_ESCRIBIR, CLIENTES_LEER, ROLE_VENDEDOR, VENTAS_LEER, VENTAS_REGISTRAR.

T-05_01_swagger.png · Captura original en el repositorio.

T-06 · Sin Authorization (propio) · PASA

Token | Usuario/token: Anónimo / Ausente

Esperado = obtenido: 401; Debe iniciar sesión para acceder a este recurso.

Petición	Esperado	Obtenido
GET /auth/me	401	401

GET /api/v1/auth/me

```
curl -X 'GET' \
  'http://localhost:8081/api/v1/auth/me' \
  -H 'accept: */*'
```

Request URL

```
http://localhost:8081/api/v1/auth/me
```

Server response

Code | Details

401 *Undocumented*

Error: response status is 401

Response body


```
{
  "timestamp": "2026-10-17T12:06:25.256341200",
  "status": 401,
  "error": "Unauthorized",
  "message": "Debe iniciar sesión para acceder a este recurso",
  "path": "/api/v1/auth/me",
  "validationErrors": null
}
```

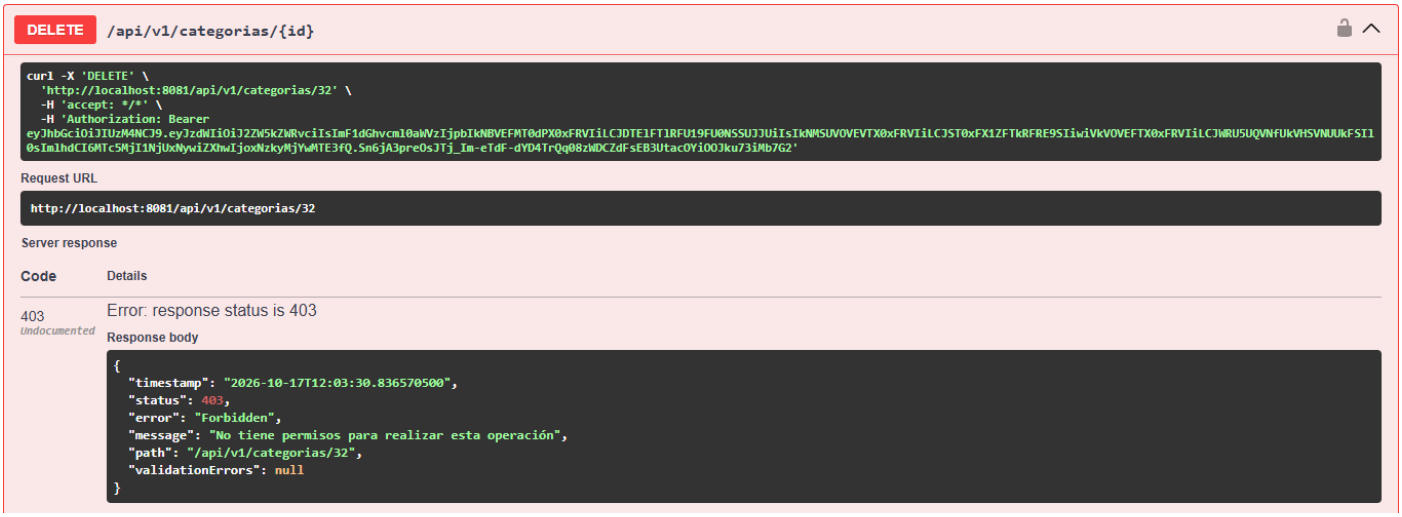

T-06_01_swagger.png · Captura original en el repositorio.

P-01 · Vendedor y categorías · PASA

Permisos | Usuario/token: vendedor / Bearer

Esperado = obtenido: 403 en POST, PUT y DELETE: No tiene permisos para realizar esta operación.

Petición	Esperado	Obtenido
POST /categorias	403	403
PUT /categorias/32	403	403
DELETE /categorias/32	403	403



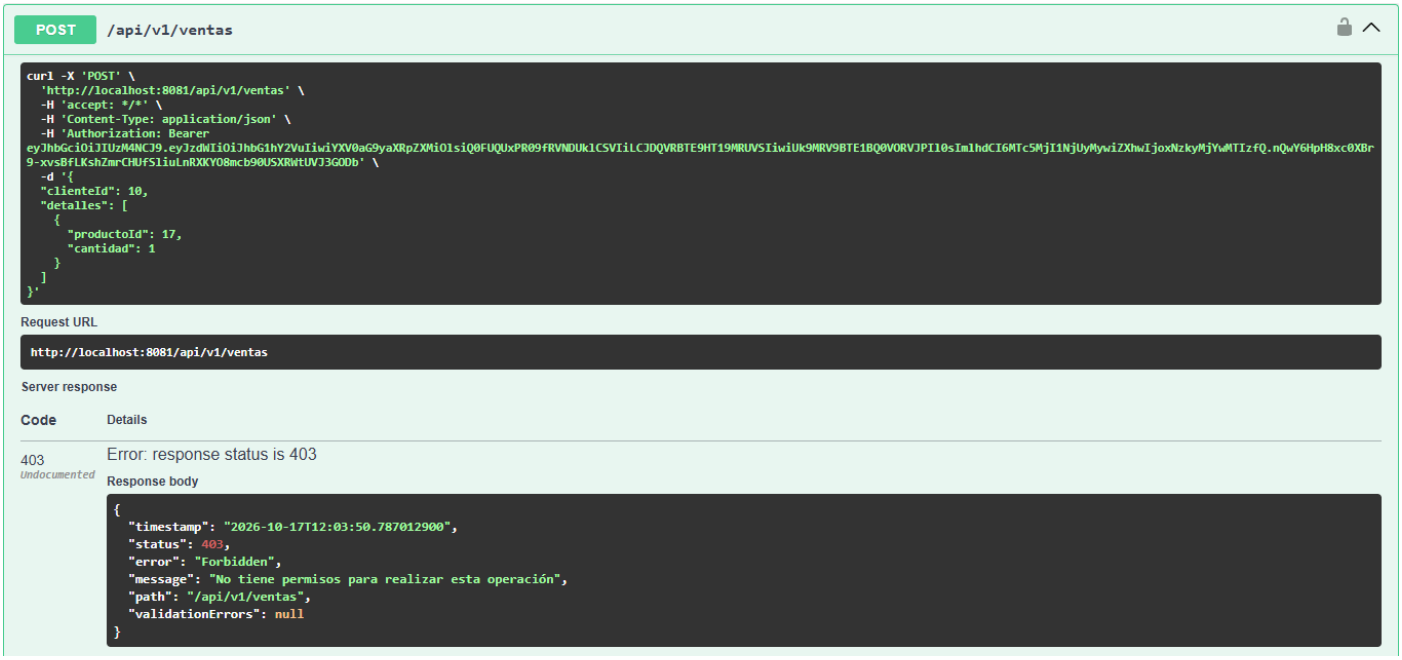
P-01_03_swagger.png · Captura original en el repositorio.

P-02 · Almacén y clientes/ventas · PASA

Permisos | Usuario/token: almacen / Bearer

Esperado = obtenido: 403 al consultar clientes y registrar ventas: No tiene permisos para realizar esta operación.

Petición	Esperado	Obtenido
GET /clientes	403	403
POST /ventas	403	403



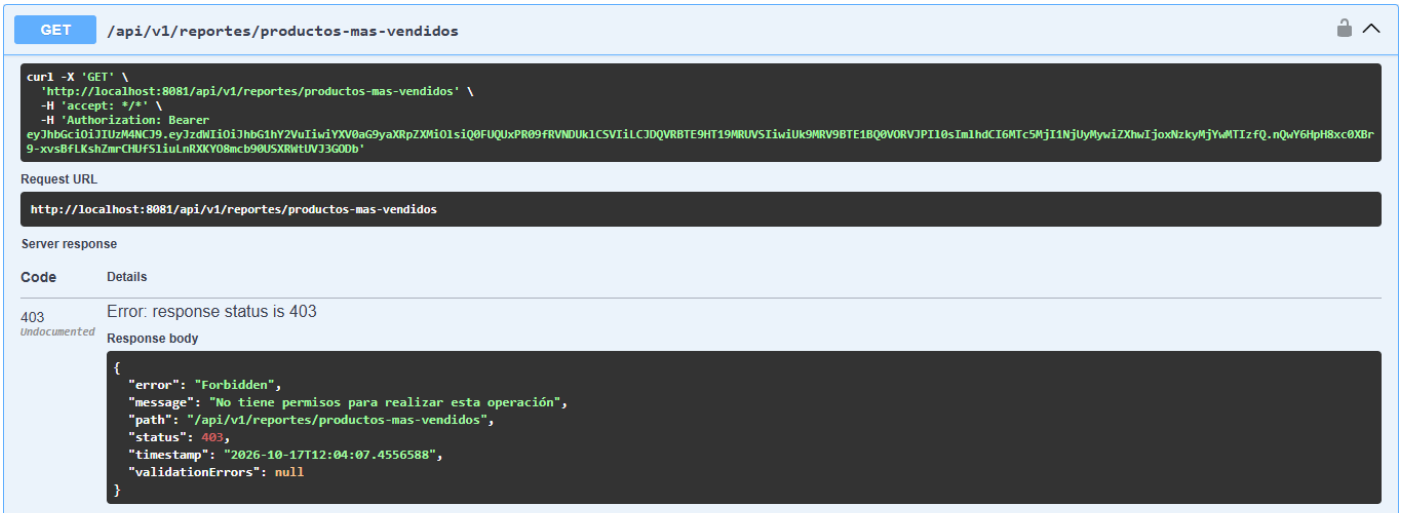
P-02_02_swagger.png · Captura original en el repositorio.

P-03 · Reporte restringido · PASA

Permisos | Usuario/token: vendedor, almacen / Bearer

Esperado = obtenido: 403 para vendedor y almacén al acceder al reporte protegido con @PreAuthorize.

Petición	Esperado	Obtenido
GET /reportes/productos-mas-vendidos	403	403
GET /reportes/productos-mas-vendidos	403	403



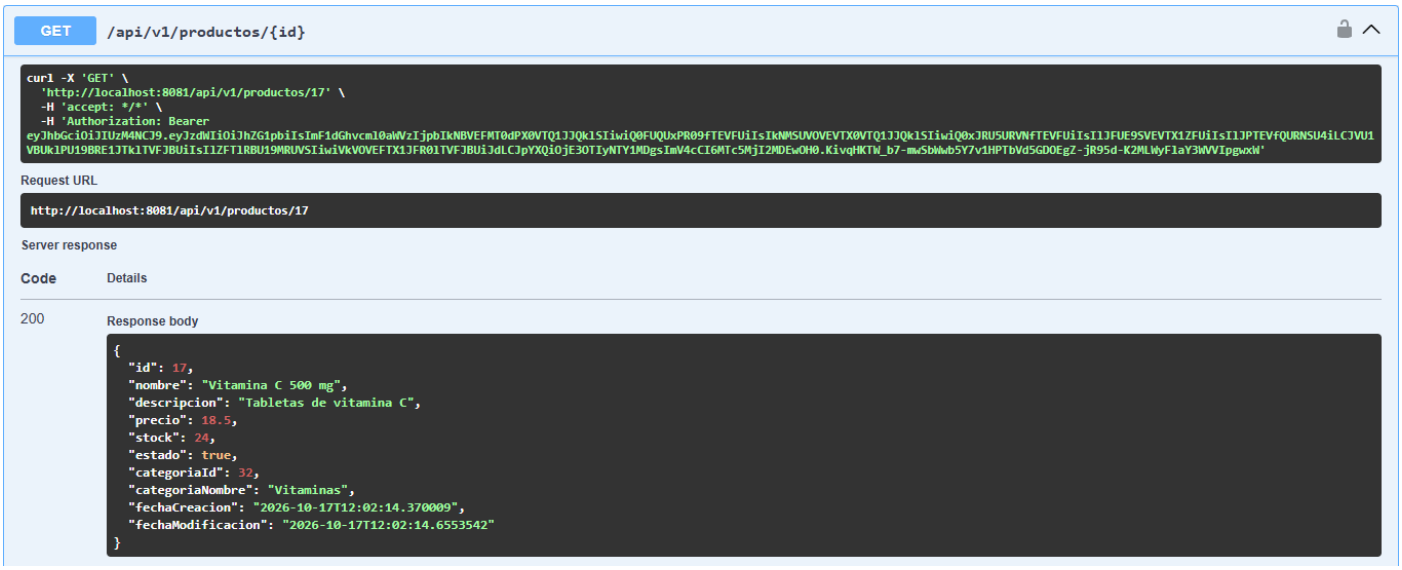
P-03_02_swagger.png · Captura original en el repositorio.

P-04 · Administrador en cada módulo · PASA

Permisos | Usuario/token: admin / Bearer

Esperado = obtenido: 200 en todos los módulos consultados por ADMIN; las respuestas contienen los datos solicitados.

Petición	Esperado	Obtenido
GET /categorias/32	200	200
GET /productos/17	200	200
GET /clientes/10	200	200
GET /ventas/16	200	200
GET /reportes/productos-mas-vendidos (fecha de ejecución)	200	200
GET /usuarios	200	200
GET /empleados	200	200
GET /roles	200	200



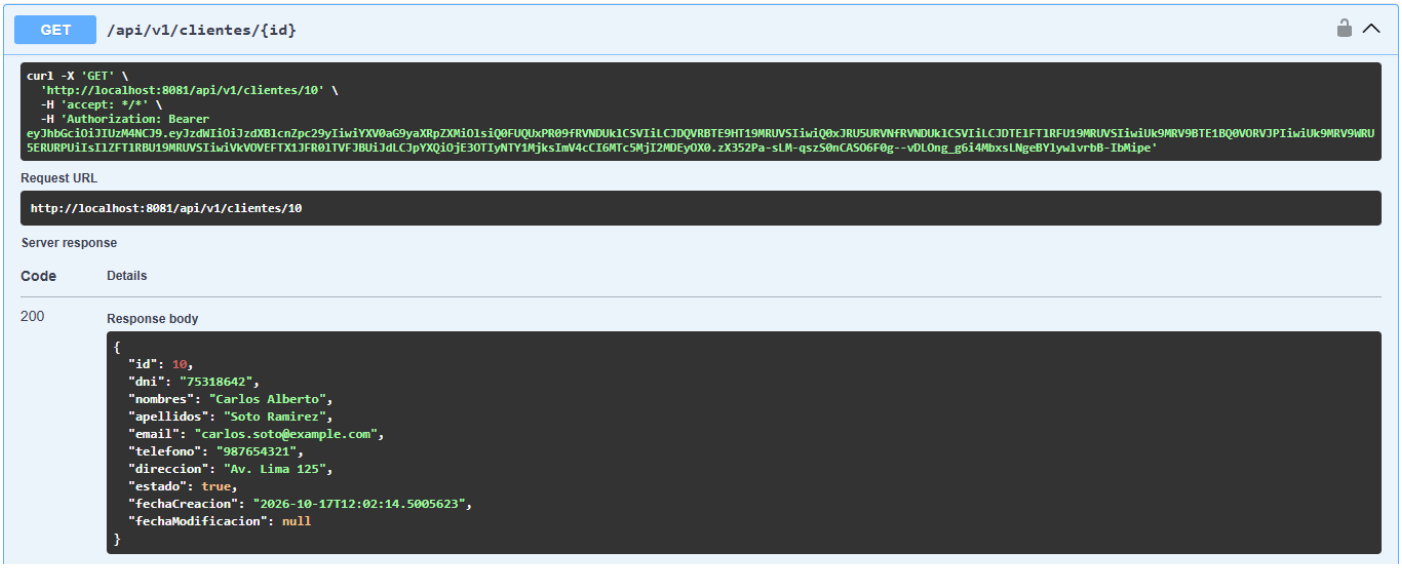
P-04_02_swagger.png · Captura original en el repositorio.

P-05 · Permisos del supervisor (propio) · PASA

Permisos | Usuario/token: supervisor / Bearer

Esperado = obtenido: 200 para supervisor tanto en catálogo como en clientes: unión de permisos de sus dos roles.

Petición	Esperado	Obtenido
GET /categorias/32	200	200
GET /clientes/10	200	200



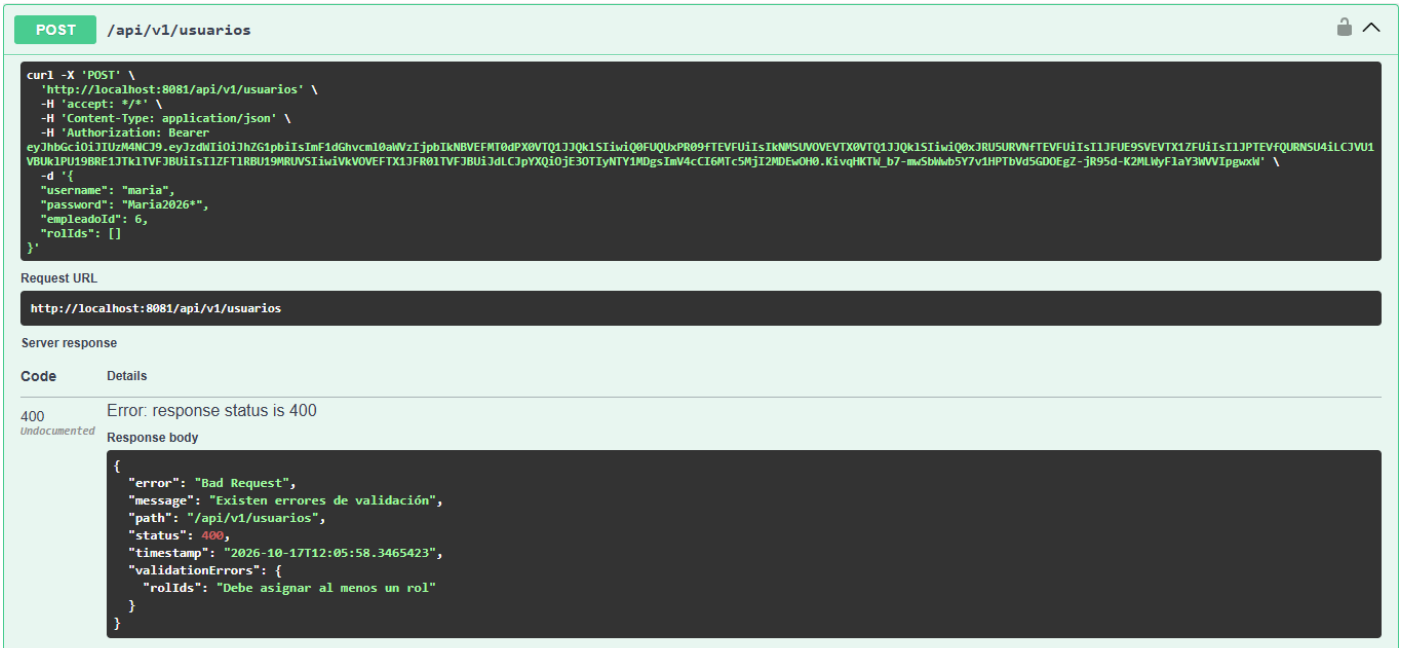
P-05_02_swagger.png · Captura original en el repositorio.

U-01 · Validación del alta · PASA

Usuarios | Usuario/token: admin / Bearer

Esperado = obtenido: 400 en ambos envíos: la contraseña necesita un número y se debe asignar al menos un rol.

Petición	Esperado	Obtenido
POST /usuarios	400	400
POST /usuarios	400	400



U-01_02_swagger.png · Captura original en el repositorio.

U-02 · Alta de María y persistencia · PASA

Usuarios | Usuario/token: admin / Bearer

Esperado = obtenido: 409 para empleado con cuenta; 201 para María, sin password en el DTO. BCrypt $2a$10$ y una relación de rol.

Petición	Esperado	Obtenido
POST /usuarios	409	409
POST /usuarios	201	201

POST /api/v1/usuarios

```
curl -X 'POST' \
  'http://localhost:8081/api/v1/usuarios' \
  -H 'accept: */*' \
  -H 'Content-Type: application/json' \
  -H 'Authorization: Bearer
eyJhbGciOiJIUzM4NCJ9.eyJzdWIiOiJhZG1pbiIsImF1dGhvcml0aWVzIjpbIkNBVEFMT0dPX0VTQ1JJQk1SIiwiQ0FUQUxPR09fTEVFUiIsIkNMSUVOVEVTX0VTQ1JJQk1SIiwiQ0xJRU5URVNfTEVFUiIsI1JFUE9SVEVTX1ZFUiIsI1JPTEVfQURNSU4iLCJVU1
VBUk1PU19BRE1JTkIsI1ZFT1RBU19MRUVSIiwiVkVOVEFTX1JFR01TVFJBUiJdLCJpYXQiOjE3OTIyNTY1MDgsImV4cCI6MTc5MjI2MDEwOH0.KivqHKTW_b7-mwSbWwb5Y7v1HPTbVd5GDOEgZ-jR95d-K2MLWyFlaY3WVVIpgwxW' \
  -d '{
  "username": "maria",
  "password": "Maria2026*",
  "empleadoId": 6,
  "rolIds": [
    2
  ]
}'
```

Request URL

```
http://localhost:8081/api/v1/usuarios
```

Server response

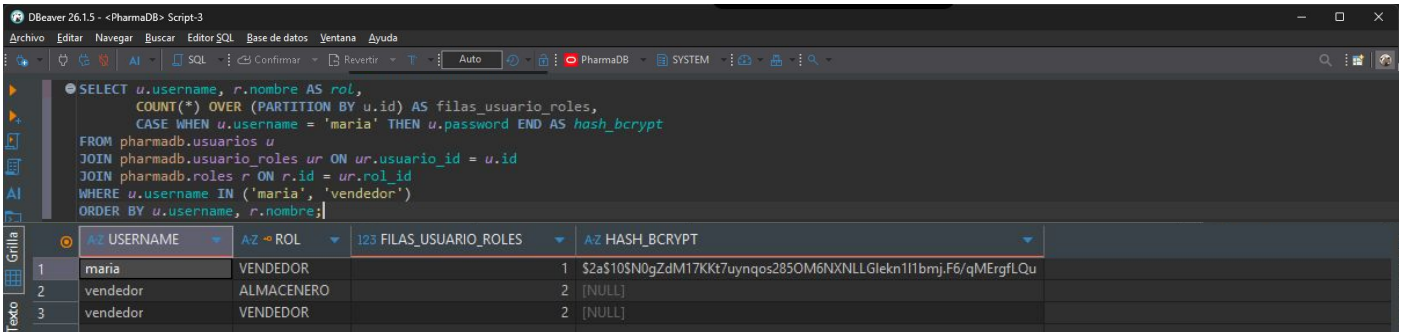
Code | Details

201 *Undocumented*

Response body


```
{
  "id": 21,
  "username": "maria",
  "empleadoId": 6,
  "empleadoNombre": "Maria Huaman Torres",
  "cargo": "Cajera",
  "roles": [
    "VENDEDOR"
  ],
  "permisos": [
    "CATALOGO_LEER",
    "CLIENTES_ESCRIBIR",
    "CLIENTES_LEER",
    "VENTAS_LEER",
    "VENTAS_REGISTRAR"
  ],
  "estado": true,
  "fechaCreacion": "2026-10-17T12:06:10.8706596"
}
```


U-02 / B-05 · DBeaver: María tiene un rol y hash BCrypt; vendedor tiene dos roles durante la prueba.



U-02_02_swagger.png · Captura original en el repositorio.

U-03 · Vendedor administra usuarios (propio) · PASA

Usuarios | Usuario/token: vendedor / Bearer

Esperado = obtenido: 403 al intentar administrar usuarios como vendedor: No tiene permisos para realizar esta operación.

Petición	Esperado	Obtenido
GET /usuarios	403	403



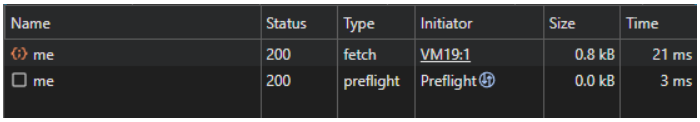
U-03_01_swagger.png · Captura original en el repositorio.

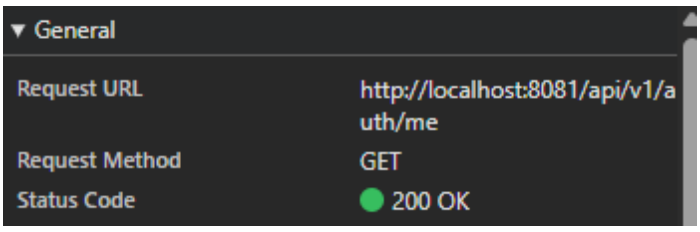
C-01 · CORS desde la SPA · PASA

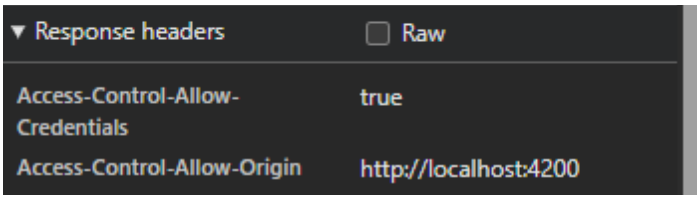
CORS | Usuario/token: vendedor / Bearer

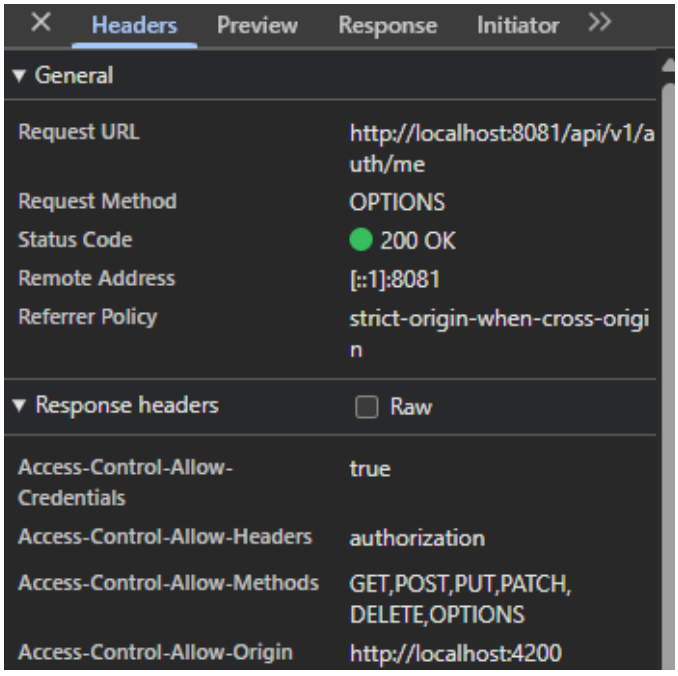
Esperado = obtenido: OPTIONS 200 y GET 200 desde localhost:4200; origen permitido y sin bloqueo CORS.

Petición	Esperado	Obtenido
OPTIONS + GET /auth/me	200	200









C-01_01_red.png · Captura original en el repositorio.

B-01 · Cambio correcto de contraseña · PASA

Gestión de acceso | Usuario/token: vendedor, Público / Bearer, Ausente

Esperado = obtenido: 204 al cambiar; login anterior 401, login nuevo 200 y token anterior 200. Log INFO sin contraseñas.

Petición	Esperado	Obtenido
PUT /auth/password	204	204
POST /auth/login · vendedor	401	401
POST /auth/login · vendedor	200	200
GET /auth/me	200	200



Registro INFO real: “Contraseña actualizada: usuario=vendedor”. Se comprobó que no aparecen las contraseñas enviadas.

B-01_01_swagger.png · Captura original en el repositorio.

B-02 · Contraseña actual incorrecta · PASA

Gestión de acceso | Usuario/token: vendedor / Bearer

Esperado = obtenido: 409; La contraseña actual no es correcta.

Petición	Esperado	Obtenido
PUT /auth/password	409	409



B-02_01_swagger.png · Captura original en el repositorio.

B-03 · Contraseña nueva idéntica · PASA

Gestión de acceso | Usuario/token: vendedor / Bearer

Esperado = obtenido: 409; La nueva contraseña debe ser distinta de la actual.

Petición	Esperado	Obtenido
PUT /auth/password	409	409

PUT /api/v1/auth/password

```
curl -X 'PUT' \
  'http://localhost:8081/api/v1/auth/password' \
  -H 'accept: */*' \
  -H 'Content-Type: application/json' \
  -H 'Authorization: Bearer
eyJhbGciOiJIUzM4NCJ9.eyJzdWIiOiJ2ZW5kZWRvciIsImF1dGhvcml0aWVzIjpbIkNBVEFMT0dPX0xFRVIiLCJDTE1FT1RFU19FU0NSSUJUiIsIkNMSUVOVEVTX0xFRVIiLCJST0xFX1ZFTkRFRE9SIiwiVkVOVEFTX0xFRVIiLCJWRU5UQVNfVHSVNUUkFSI1
0sImlhdCI6MTc5MjI1NjUxNywiZXhwIjoxNzkyMjYwMTE3fQ.Sn6jA3preOsJTj_Im-eTdF-dYD4TrQq08zWDCZdFsEB3UtacOYiOOJku73iMb7G2' \
  -d '{
  "passwordActual": "Vendedor2026*",
  "passwordNueva": "Vendedor2026*"
}'
```

Request URL

```
http://localhost:8081/api/v1/auth/password
```

Server response

Code	Details
409 *Undocumented*	Error: response status is 409 Response body

```
{
  "error": "Conflict",
  "message": "La nueva contraseña debe ser distinta de la actual",
  "path": "/api/v1/auth/password",
  "status": 409,
  "timestamp": "2026-10-17T12:07:07.4787581",
  "validationErrors": null
}
```

B-03_01_swagger.png · Captura original en el repositorio.

B-04 · Formato de la nueva contraseña · PASA

Gestión de acceso | Usuario/token: vendedor / Bearer

Esperado = obtenido: 400 en los tres envíos: contraseña sin número, demasiado corta o mayor a 72 caracteres.

Petición	Esperado	Obtenido
PUT /auth/password · sin número	400	400
PUT /auth/password · corta	400	400
PUT /auth/password · más de 72 caracteres	400	400

PUT /api/v1/auth/password

```
curl -X 'PUT' \
  'http://localhost:8081/api/v1/auth/password' \
  -H 'accept: */*' \
  -H 'Content-Type: application/json' \
  -H 'Authorization: Bearer
eyJhbGciOiJIUzM4NCJ9.eyJzdWIiOiJ2ZW5kZWRvciIsImF1dGhvcml0aWVzIjpbIkNBVEFMT0dPX0xFRVIiLCJDTE1FT1RFU19FU0NSSUJUiIsIkNMSUVOVEVTX0xFRVIiLCJST0xFX1ZFTkRFRE9SIiwiVkVOVEFTX0xFRVIiLCJWRU5UQVNfVHSVNUUkFSI1
0sImlhdCI6MTc5MjI1NjUxNywiZXhwIjoxNzkyMjYwMTE3fQ.Sn6jA3preOsJTj_Im-eTdF-dYD4TrQq08zWDCZdFsEB3UtacOYiOOJku73iMb7G2' \
  -d '{
  "passwordActual": "Vendedor2026*",
  "passwordNueva": "abcdefgh"
}'
```

Request URL

```
http://localhost:8081/api/v1/auth/password
```

Server response

Code	Details
400 *Undocumented*	Error: response status is 400 Response body

```
{
  "error": "Bad Request",
  "message": "Existen errores de validación",
  "path": "/api/v1/auth/password",
  "status": 400,
  "timestamp": "2026-10-17T12:07:13.5073816",
  "validationErrors": {
    "passwordNueva": "La contraseña debe contener al menos una letra y un número"
  }
}
```

B-04_01_swagger.png · Captura original en el repositorio.

B-05 · Asignación de roles y mismo JWT · PASA

Gestión de acceso | Usuario/token: admin, vendedor / Bearer

Esperado = obtenido: 200 al asignar dos roles y 200 en PUT categoría con el mismo token. Oracle guarda dos relaciones.

Petición	Esperado	Obtenido
PUT /usuarios/2/roles	200	200
PUT /categorias/32	200	200



Persistencia: la captura compartida de DBeaver incluida en U-02 muestra ALMACENERO y VENDEDOR (dos filas). El filtro recarga permisos por username en cada petición.

B-05_02_swagger.png · Captura original en el repositorio.

B-06 · Reglas al asignar roles · PASA

Gestión de acceso | Usuario/token: admin / Bearer

Esperado = obtenido: 400 por roles vacíos; 404 por usuario o rol inexistentes; 409 al intentar quitarse ADMIN.

Petición	Esperado	Obtenido
PUT /usuarios/2/roles	400	400
PUT /usuarios/999999/roles	404	404
PUT /usuarios/2/roles	404	404
PUT /usuarios/1/roles	409	409



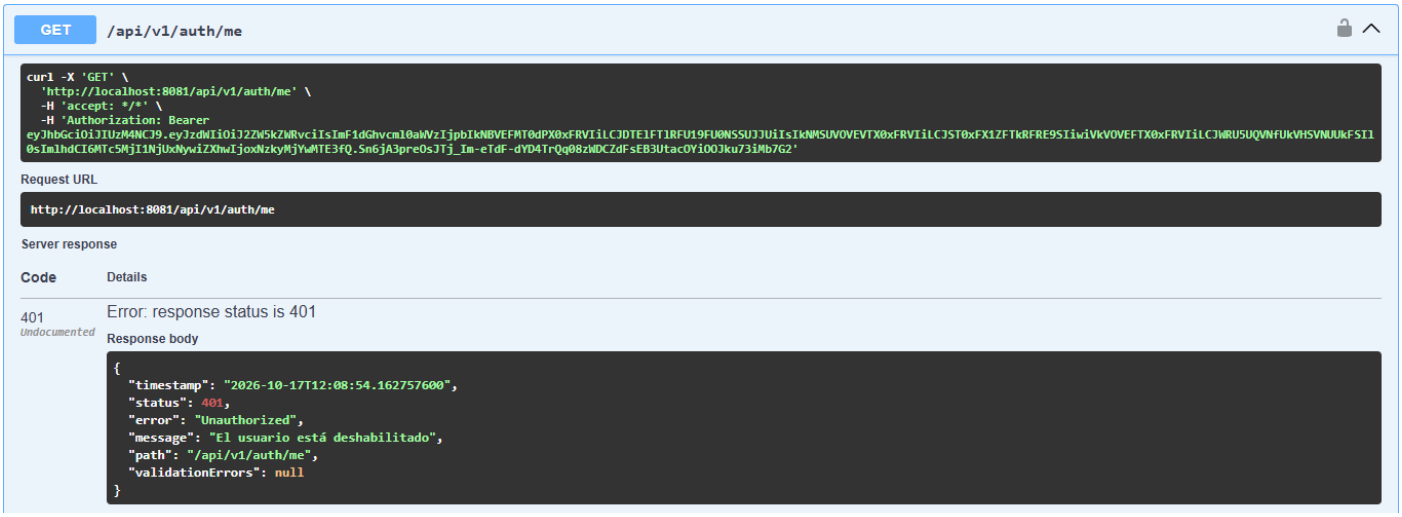
B-06_04_swagger.png · Captura original en el repositorio.

B-07 · Desactivación y reactivación · PASA

Gestión de acceso | Usuario/token: admin, vendedor, Público / Bearer, Ausente

Esperado = obtenido: 200 al desactivar; token previo 401 y login 401; 200 al reactivar y al reutilizar el token.

Petición	Esperado	Obtenido
PATCH /usuarios/2/estado	200	200
GET /auth/me	401	401
POST /auth/login · vendedor	401	401
PATCH /usuarios/2/estado	200	200
GET /auth/me	200	200



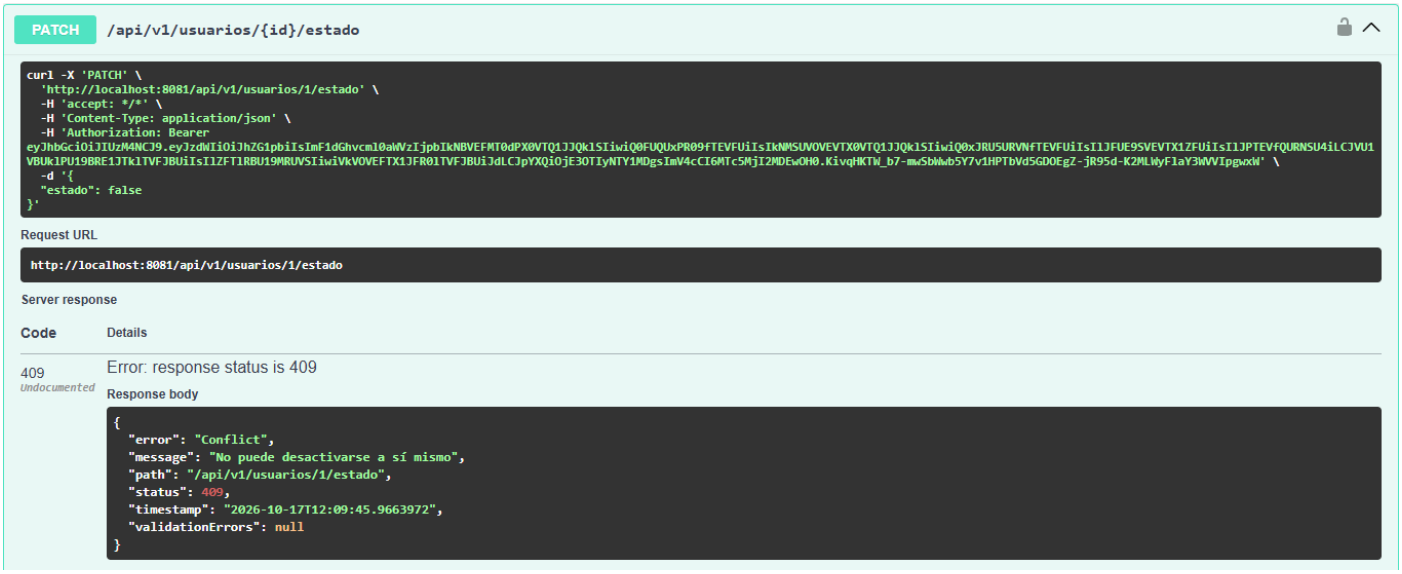
B-07_02_swagger.png · Captura original en el repositorio.

B-08 · Permisos y autodesactivación · PASA

Gestión de acceso | Usuario/token: vendedor, admin / Bearer

Esperado = obtenido: 403 sin permiso; 404 para usuario inexistente; 409 al intentar desactivarse el administrador.

Petición	Esperado	Obtenido
PATCH /usuarios/2/estado	403	403
PUT /usuarios/2/roles	403	403
PATCH /usuarios/999999/estado	404	404
PATCH /usuarios/1/estado	409	409



B-08_04_swagger.png · Captura original en el repositorio.